ABRACADABRA MONEY · SECURITY REVIEW

Abracadabra Money CauldronFeeWithdrawer for SpellPower Staking.

A security review of CauldronFeeWithdrawer for SpellPower Staking.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Abracadabra Money	CauldronFeeWithdrawer for SpellPower Staking	Guardian	January 2 – January 8, 2025	January 8, 2025

§ 00

Contents.

14 pages: overview, confidence ranking, scope, 6 findings, disclaimer, and about Guardian.

§ 01 Overview P. 03
§ 02 Confidence Ranking P. 04
§ 03 Scope & Classifications P. 05
§ 04 Findings P. 06
Main Review · 6 findings P. 07
§ 05 Disclaimer P. 13
§ 06 About Guardian P. 14

§ 01

Overview.

Guardian reviewed CauldronFeeWithdrawer for SpellPower Staking across a single review round. The final report includes 6 Low findings.

AUDIT FIRM
Guardian

CLIENT
Abracadabra Money

PROJECT
CauldronFeeWithdrawer for SpellPower Staking

PREPARED BY
Guardian

AUDIT WINDOW
January 2 – January 8, 2025

FINAL REPORT
January 8, 2025

REPOSITORY
`https://github.com/Abracadabra-money/abracadabra-money-contracts`

METHODOLOGY
Smart contract · Manual · Main Review

MAIN REVIEW COMMIT
`a45aa7f01e63`

1.1 Confidence Ranking

5 / 5
Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer's assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	**0**	0	0	0	0
High	**0**	0	0	0	0
Medium	**0**	0	0	0	0
Low	**6**	0	2	0	4
Informational	**0**	0	0	0	0
All severities	**6**	**0**	**2**	**0**	**4**

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed CauldronFeeWithdrawer for SpellPower Staking in `https://github.com/Abracadabra-money/abracadabra-money-contracts`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH	Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.
IMPACT · MEDIUM	Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.
IMPACT · LOW	Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.
LIKELIHOOD · HIGH	Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.
LIKELIHOOD · MEDIUM	Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.
LIKELIHOOD · LOW	Unlikely to ever occur in production.

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in. Status is where each finding ended up; its own page says how.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
L-01	Unused Error	Optimization	LOW	RESOLVED	p. 7
L-02	Missing Fee Collector Check	Validation	LOW	ACKNOWLEDGED	p. 8
L-03	Unused _cauldronPredicate function	Warning	LOW	RESOLVED	p. 9
L-04	Upgradeable Friendly Contracts Are Not Used	Best Practices	LOW	ACKNOWLEDGED	p. 10
L-05	Staking Contract Is Not Configured	Configuration	LOW	RESOLVED	p. 11
L-06	Unnecessary Owner Initialization	Superfluous Code	LOW	RESOLVED	p. 12

LOW **L-01** RESOLVED

Unused Error

CATEGORY	Optimization
LOCATION	`CauldronFeeWIthdrawer.sol: 32`
REVIEW	Main Review

DESCRIPTION

In the `CauldronFeeWithdrawer` contract the `ErrNotRegistered` error is unused.

RECOMMENDATION

Implement the corresponding cauldron validation in the `withdraw` function or remove the `ErrNotRegistered` error.

RESOLUTION

Status: Resolved.

LOW **L-02**

ACKNOWLEDGED

Missing Fee Collector Check

CATEGORY	Validation
LOCATION	`CauldronFeeWithdrawer.sol: 153`
REVIEW	Main Review

DESCRIPTION

In the `distribute` function the treasury share of mim rewards is transferred to the `feeCollector` even if the `feeCollector` has not yet been assigned.
This introduces the risk of sending the treasury fees to the zero address if the system is not initialized properly.

RECOMMENDATION

Consider changing the `if (treasuryAmount > 0)` validation to `if (treasuryAmount > 0 && feeCollector != address(0))`.
Any mim left in the `CauldronFeeWithdrawer` contract after failing this check that should go to the treasury can be withdrawn with the `execute` function calling the mim contract directly.

RESOLUTION

Status: Acknowledged.

LOW **L-03** RESOLVED

Unused _cauldronPredicate function

CATEGORY	Warning
LOCATION	`CauldronFeeWithdrawer.s.sol: 54`
REVIEW	Main Review

DESCRIPTION

In the `CauldronFeeWithdrawer` deployment script there is an unused `_cauldronPredicate` function.

RECOMMENDATION

Implement the use case for the `_cauldronPredicate` or consider removing it.

RESOLUTION

Status: Resolved.

LOW **L-04**

ACKNOWLEDGED

Upgradeable Friendly Contracts Are Not Used

CATEGORY	Best Practices
LOCATION	`CauldronFeeWithdrawer.sol`
REVIEW	Main Review

DESCRIPTION

The `CauldronFeeWithdrawer` contract is a UUPS upgradeable contract, however there are contracts which are not upgradeable friendly which the `CauldronFeeWithdrawer` inherits from.
The `FeeCollectable` and `OwnableOperators` contracts include storage variables that do not use namespaced storage nor include a storage gap at the end.
As a result if an upgrade takes place and the storage layout of either of the `FeeCollectable` and `OwnableOperators` contracts is changed this can result in unexpected storage issues.

RECOMMENDATION

Since the `FeeCollectable` and `OwnableOperators` contracts are already used in tandem with other contracts which might be upgradeable, it is sensitive to update them and potentially accidentally change the storage layout of those proxy contracts in an unexpected way.
Instead just note this behavior and exercise caution when initiating any upgrades.

RESOLUTION

Status: Acknowledged.

LOW **L-05**

RESOLVED

Staking Contract Is Not Configured

CATEGORY	Configuration
LOCATION	`CauldronFeeWithdrawer.sol`
REVIEW	Main Review

DESCRIPTION

In the `CauldronFeeWithdrawer` script there is no configuration of the staking contract.

RECOMMENDATION

Consider adding logic to configure the staking contract for the Arbitrum deployment of the `CauldronFeeWithdrawer` contract.

RESOLUTION

Status: Resolved.

LOW **L-06** RESOLVED

Unnecessary Owner Initialization

CATEGORY	Superfluous Code
LOCATION	`CauldronFeeWithdrawer.sol: 51`
REVIEW	Main Review

DESCRIPTION

In the constructor for the `CauldronFeeWithdrawer` the `_initializeOwner` function is called, however it is unnecessary to assign an owner for the implementation contract. Furthermore the owner is assigned as the zero address in the deployment script, meaning that this function does not update any storage and instead merely emits the `OwnershipTransferred` event.

RECOMMENDATION

Remove the `_initializeOwner` call from the `CauldronFeeWithdrawer` constructor.

RESOLUTION

Status: Resolved.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

$45B+
DIGITAL ASSETS UNDER REVIEW

200+
ENGAGEMENTS COMPLETED

500+
CRITICAL & HIGH FINDINGS REPORTED

Reach us at audits@guardianaudits.com.